Sample: Security review of an AI-built Next.js, Supabase, Stripe app

Sample on synthetic data

The problem (example client brief)

Our B2B ordering app was built with Claude Code over several months. Before real card and customer data goes in, we need an independent senior engineer to review the code, give us a written report ranked by severity, and then help with the cleanup.

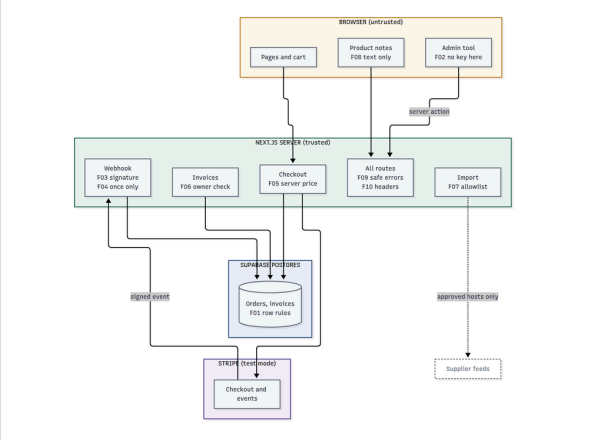
What I built

- A small multi-tenant ordering app with sign-up, product list, cart, Stripe Checkout, order history, invoice download, an admin page and an import-from-URL feature.
- The app as a fast AI-assisted build might ship it, tagged `v0-as-shipped`, with ten seeded flaws.
- One exploit test per flaw. Each fails on the old code and passes on the fixed code, with one fix commit per finding. The F05 and F04 follow-ups are in merge 51f1940.
- A written findings report ranked by severity, with evidence for each item and a 30-day cleanup plan.
- A CI pipeline that runs the tests and scanners and fails if any flaw comes back.

What the sample proves

Each figure below is read from CI output files.

- 10 of the 10 seeded flaws can be exploited on `v0-as-shipped`, and 10 of 10 are stopped on `main`.
- 105 unit tests pass, with 98.5% line coverage on the library code and server actions (the gate is 80%).
- 9 database policy checks pass on `main`, and 7 of them fail on the old code.
- A browser smoke test passes: sign up, add to cart, check out against a Stripe test double, see the paid order.
- Semgrep, gitleaks and osv-scanner come back clean. The ZAP baseline scan reports 0 failures and 60 passed checks.



How an engagement would run

Week one. I read the code with you, map where data and money move, run the scanners, and write a test for each serious risk. You get the written report, ranked by severity, with a plain-words note on each finding.

Week two. We fix the High items in order, each with a test that proves it. I add a CI check so the same flaws cannot return, and leave you a cleanup plan for the following weeks.

Background

I have run engineering where every decision had to stand up to an audit: a 350-engineer organization producing regulated correspondence for five top-10 US health insurers under HIPAA, SOX and PCI DSS. I also led the response to a twelve-day hard-down ransomware crisis with no disaster recovery in place, and completed the Azure migration in 75 days.

Kunjar Bhaduri. I lead and deliver the work myself, using frontier AI tooling to move fast.